



LAB 3: PROTOCOLOS DE COMUNICACIÓN SEGUROS

OBJETIVO TÉCNICO

- ▶ CAPTURAR TRÁFICO HTTP
- ▶ DEMOSTRAR EXPOSICIÓN DE CREDENCIALES
- ▶ IMPLEMENTAR HTTPS
- ▶ VALIDAR CIFRADO
- ▶ CONFIGURAR SSH SEGURO
- ▶ "EL OBJETIVO FUE VALIDAR EMPÍRICAMENTE LA SEGURIDAD DE DISTINTOS PROTOCOLOS"

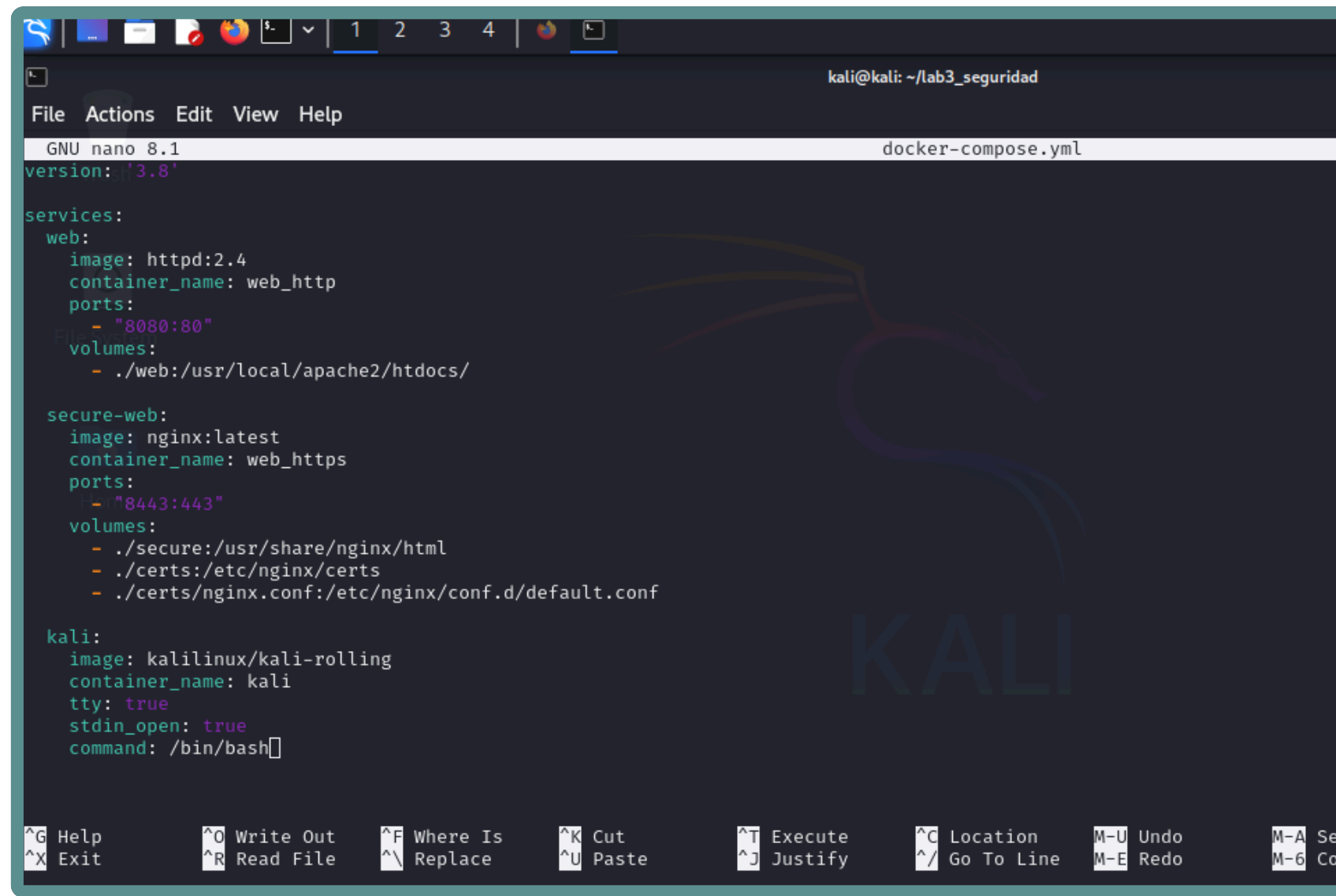
ENTORNO DE PRUEBA

- 

Se creó un entorno con tres contenedores para simular un ataque y su posterior mitigación

[illegible]

CONFIGURACIÓN DEL LAB



```
GNU nano 8.1 docker-compose.yml
version: '3.8'

services:
  web:
    image: httpd:2.4
    container_name: web_http
    ports:
      - "8080:80"
    volumes:
      - ./web:/usr/local/apache2/htdocs/

  secure-web:
    image: nginx:latest
    container_name: web_https
    ports:
      - "8443:443"
    volumes:
      - ./secure:/usr/share/nginx/html
      - ./certs:/etc/nginx/certs
      - ./certs/nginx.conf:/etc/nginx/conf.d/default.conf

  kali:
    image: kalilinux/kali-rolling
    container_name: kali
    tty: true
    stdin_open: true
    command: /bin/bash
```

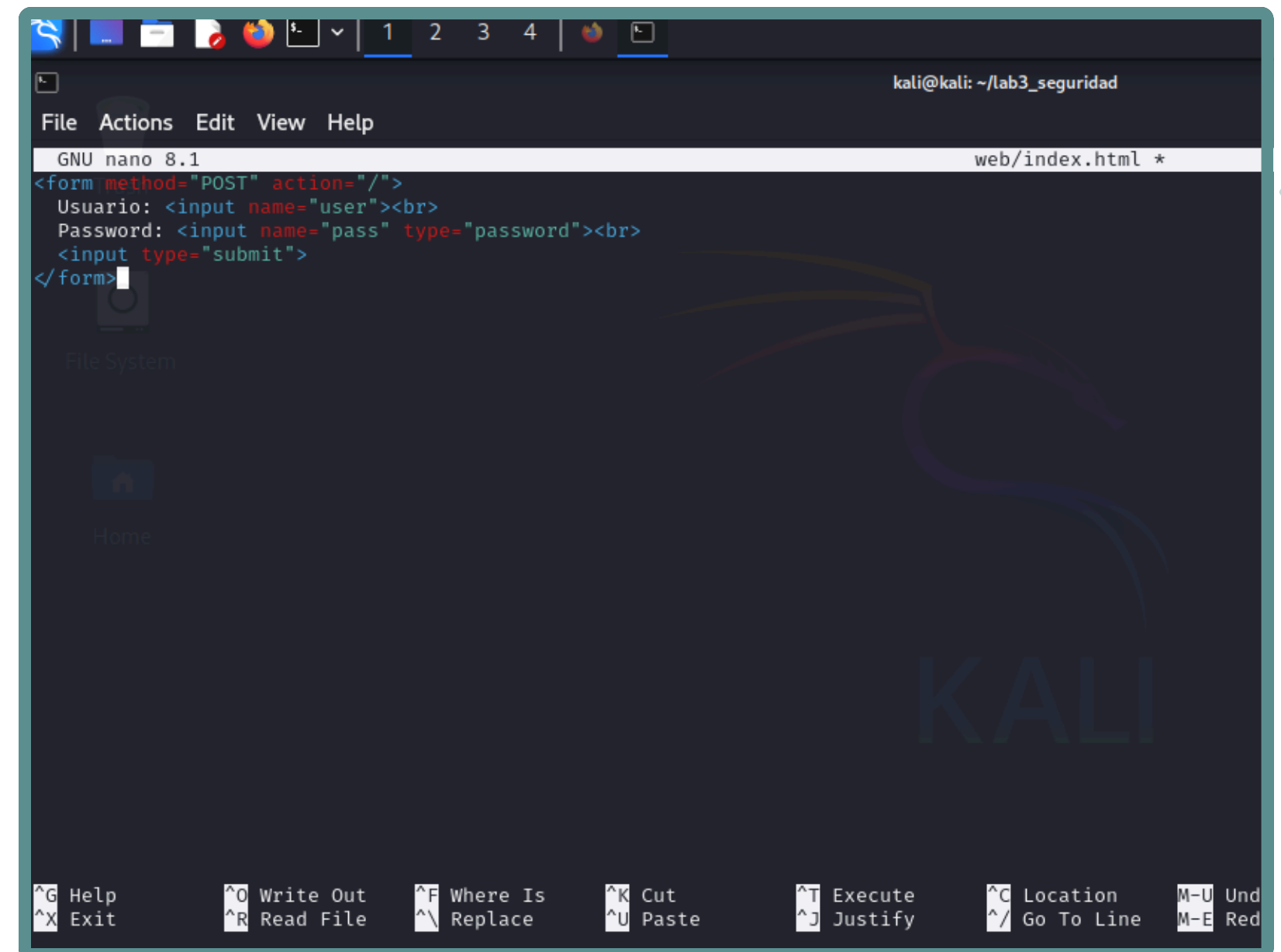
Se definieron servicios separados para tráfico inseguro y seguro:

- Servicio HTTP: puerto 8080
- Servicio HTTPS: puerto 8443.
- Red: lab3_seguridad_default

El archivo `docker-compose.yml` configura ambos servicios de forma aislada para demostrar la diferencia entre comunicación cifrada y no cifrada.

FORMULARIO WEB

- Se implementó un formulario HTML con método POST para simular el envío de credenciales al servidor.
 - Método: POST al endpoint /
 - Campos: user, pass
 - Propósito: Capturar datos de autenticación
- "Se implementó un formulario para simular envío de credenciales"



The screenshot shows a Kali Linux terminal window with the nano text editor open. The editor is editing a file named `web/index.html`. The code being edited is an HTML form with the following structure:

```
<form method="POST" action="/">
  Usuario: <input name="user"><br>
  Password: <input name="pass" type="password"><br>
  <input type="submit">
</form>
```

The terminal window has a dark theme with a Kali Linux logo in the background. The nano editor's menu bar is visible at the top, and the status bar at the bottom shows various keyboard shortcuts.

INICIO DE CAPTURA HTTP

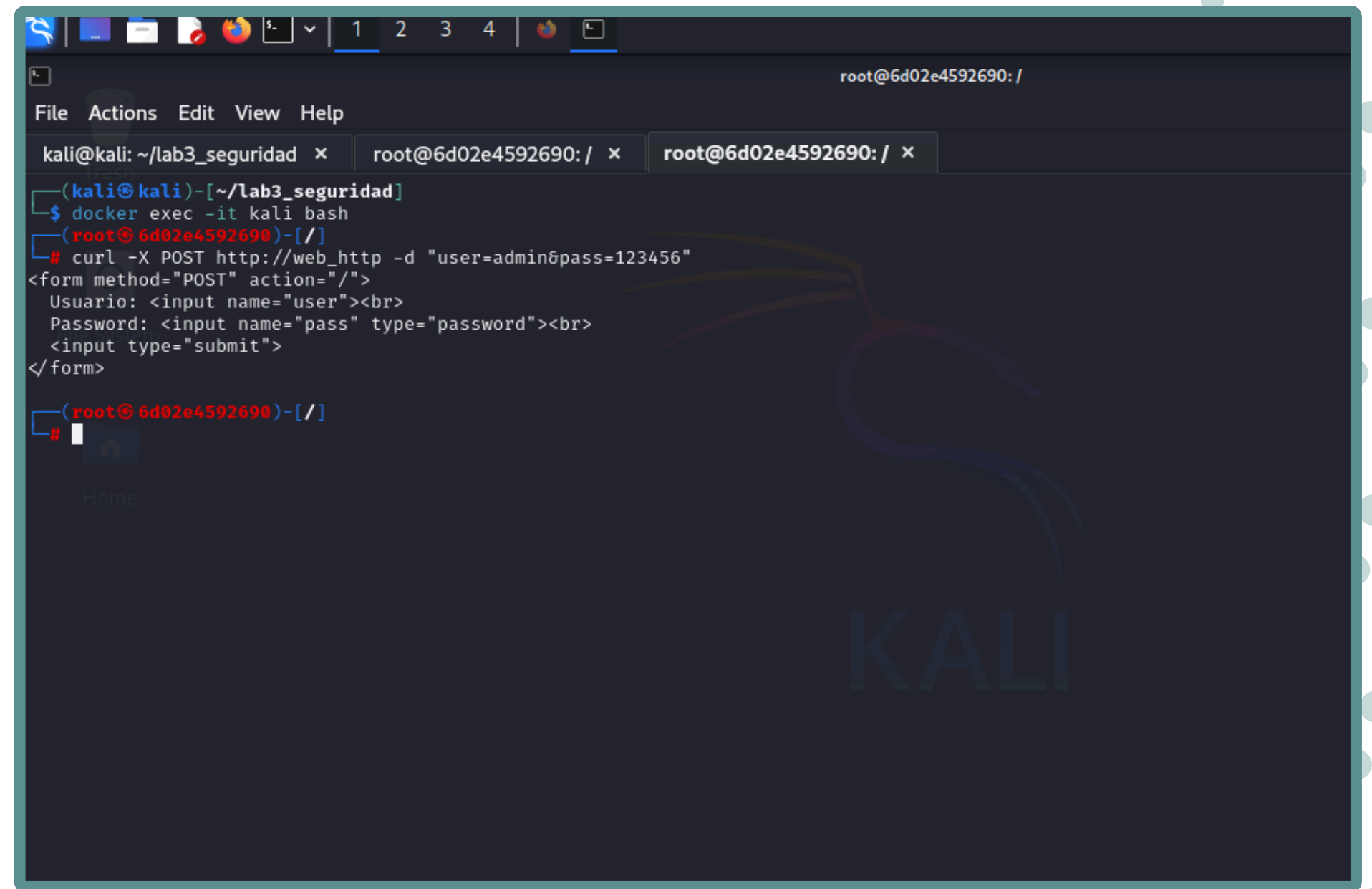


```
root@6d02e4592690: /  
# tcpdump -i eth0 -A port 80  
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode  
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes  
02:00:40.552225 IP 6d02e4592690.46634 > web_http.lab3_seguridad_default.80: Flags  
[S], seq 2227963935, win 32120, options [mss 1460,sackOK,TS val 2298361208 ecr 0  
,nop,wscale 7], length 0  
E..<.x@.@.....*P.....}xX\.....  
..5x.....  
02:00:40.552259 IP web_http.lab3_seguridad_default.80 > 6d02e4592690.46634: Flags  
[S.], seq 1298599013, ack 2227963936, win 31856, options [mss 1460,sackOK,TS val  
2601232418 ecr 2298361208,nop,wscale 7], length 0  
E..<..@.@.....*P.*Mg.e... ..lpX\.....  
...."..5x....  
02:00:40.552277 IP 6d02e4592690.46634 > web_http.lab3_seguridad_default.80: Flags  
[.], ack 1, win 251, options [nop,nop,TS val 2298361208 ecr 2601232418], length  
0  
E..4.y@.@.....*P... Mg.f....XT.....  
..5x..."  
02:00:40.552411 IP 6d02e4592690.46634 > web_http.lab3_seguridad_default.80: Flags  
[P.], seq 1:165, ack 1, win 251, options [nop,nop,TS val 2298361208 ecr 26012324  
18], length 164: HTTP: POST / HTTP/1.1  
E....z@.@..x.....*P... Mg.f....X.....  
..5x..."POST / HTTP/1.1  
Host: web_http  
User-Agent: curl/8.19.0  
Accept: /*/*  
Content-Length: 22  
Content-Type: application/x-www-form-urlencoded  
ChatGPT can make mistakes. Check important info. See Cookie Preferences.
```

► **Comando: tcpdump -i eth0 -A port 80**
Se inicia la captura de paquetes en la interfaz eth0, filtrando tráfico del puerto 80 (HTTP). La opción -A muestra el contenido en ASCII para visualizar datos en texto plano.
"Se comenzó la captura de tráfico en texto plano sobre HTTP"

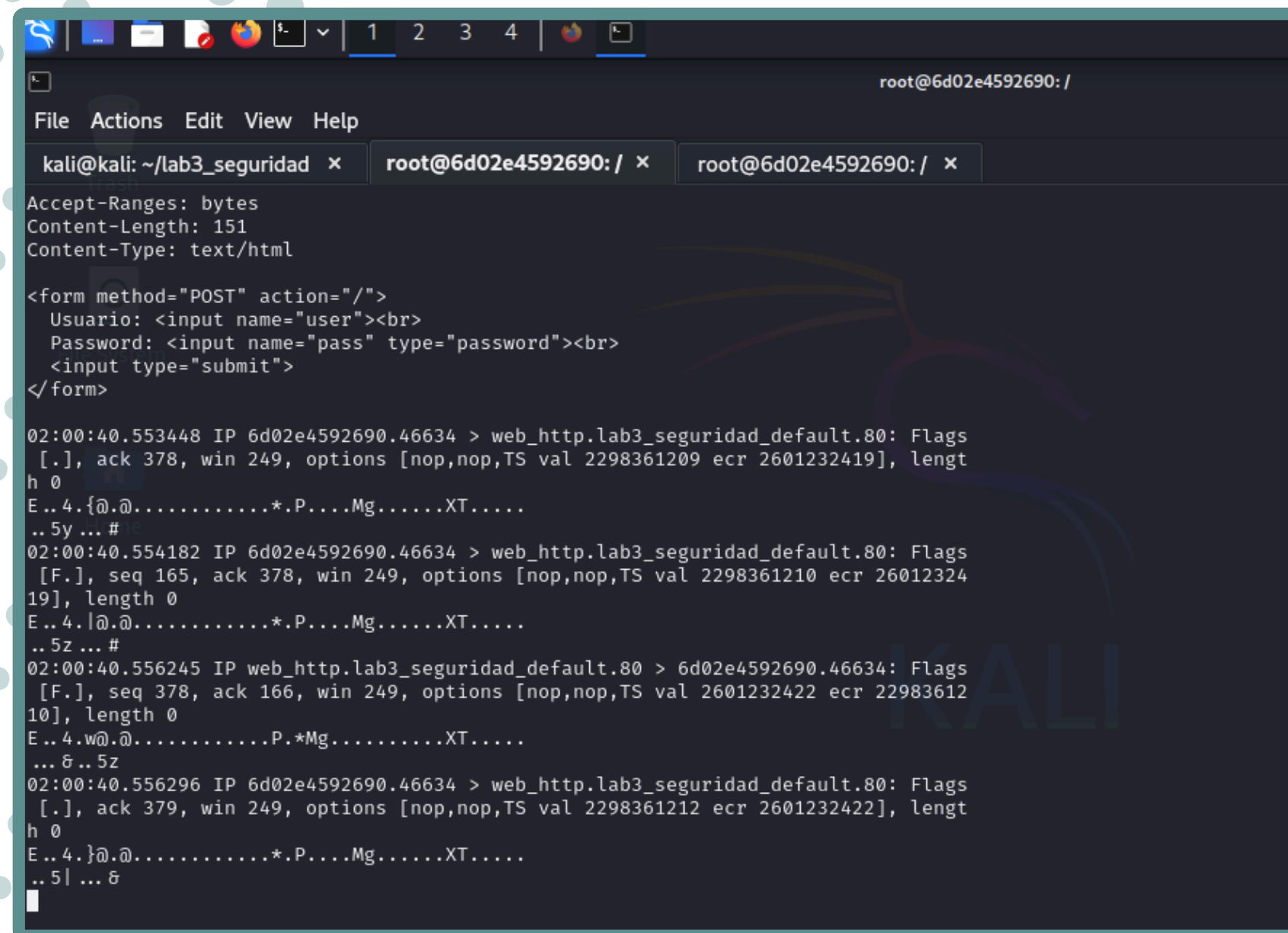
GENERACIÓN DE TRÁFICO

- Comando ejecutado desde Kali:
`curl -X POST http://web_http -d "user=admin&pass=123456"`
"Se generó tráfico controlado desde Kali para garantizar que sea interceptado"



```
root@6d02e4592690: /  
File Actions Edit View Help  
kali@kali: ~/lab3_seguridad x root@6d02e4592690: / x root@6d02e4592690: / x  
(kali@kali)-[~/lab3_seguridad]  
$ docker exec -it kali bash  
(root@6d02e4592690)-[/]  
# curl -X POST http://web_http -d "user=admin&pass=123456"  
<form method="POST" action="/">  
  Usuario: <input name="user"><br>  
  Password: <input name="pass" type="password"><br>  
  <input type="submit">  
</form>  
(root@6d02e4592690)-[/]  
#
```

EVIDENCIA: CREDENCIALES EXPUESTAS



```
root@6d02e4592690: /
File Actions Edit View Help
kali@kali: ~/lab3_seguridad x root@6d02e4592690: / x root@6d02e4592690: / x
Accept-Ranges: bytes
Content-Length: 151
Content-Type: text/html

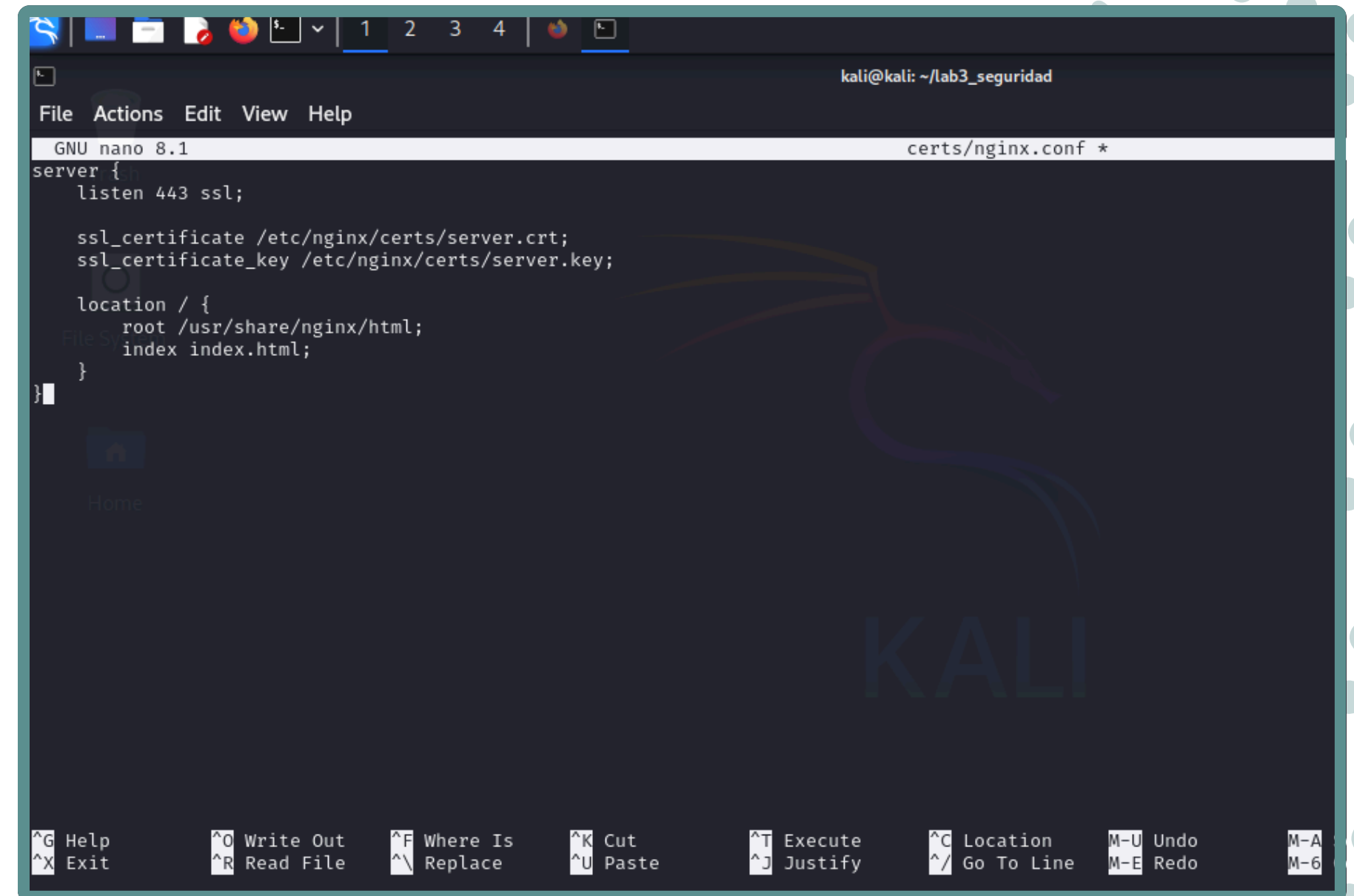
<form method="POST" action="/">
  Usuario: <input name="user"><br>
  Password: <input name="pass" type="password"><br>
  <input type="submit">
</form>

02:00:40.553448 IP 6d02e4592690.46634 > web_http.lab3_seguridad_default.80: Flags
[.], ack 378, win 249, options [nop,nop,TS val 2298361209 ecr 2601232419], lengt
h 0
E..4.{@.@.....*.P....Mg.....XT.....
..5y ... #
02:00:40.554182 IP 6d02e4592690.46634 > web_http.lab3_seguridad_default.80: Flags
[F.], seq 165, ack 378, win 249, options [nop,nop,TS val 2298361210 ecr 26012324
19], length 0
E..4.{@.@.....*.P....Mg.....XT.....
..5z ... #
02:00:40.556245 IP web_http.lab3_seguridad_default.80 > 6d02e4592690.46634: Flags
[F.], seq 378, ack 166, win 249, options [nop,nop,TS val 2601232422 ecr 22983612
10], length 0
E..4.w@.@.....P.*Mg.....XT.....
...6..5z
02:00:40.556296 IP 6d02e4592690.46634 > web_http.lab3_seguridad_default.80: Flags
[.], ack 379, win 249, options [nop,nop,TS val 2298361212 ecr 2601232422], lengt
h 0
E..4.}@.@.....*.P....Mg.....XT.....
..5| ... 6
```

- ▶ La captura tcpdump revela claramente los datos transmitidos:
user=admin&pass=123456
- Explicación técnica: El protocolo HTTP no implementa cifrado, exponiendo el payload completo en texto plano.
- "Se evidencia que HTTP transmite credenciales en texto plano, lo que representa un riesgo crítico de seguridad"

IMPLEMENTACIÓN HTTPS

► Se generó un certificado SSL autofirmado y se configuró nginx para escuchar en el puerto 443 (redireccionado a 8443 local).



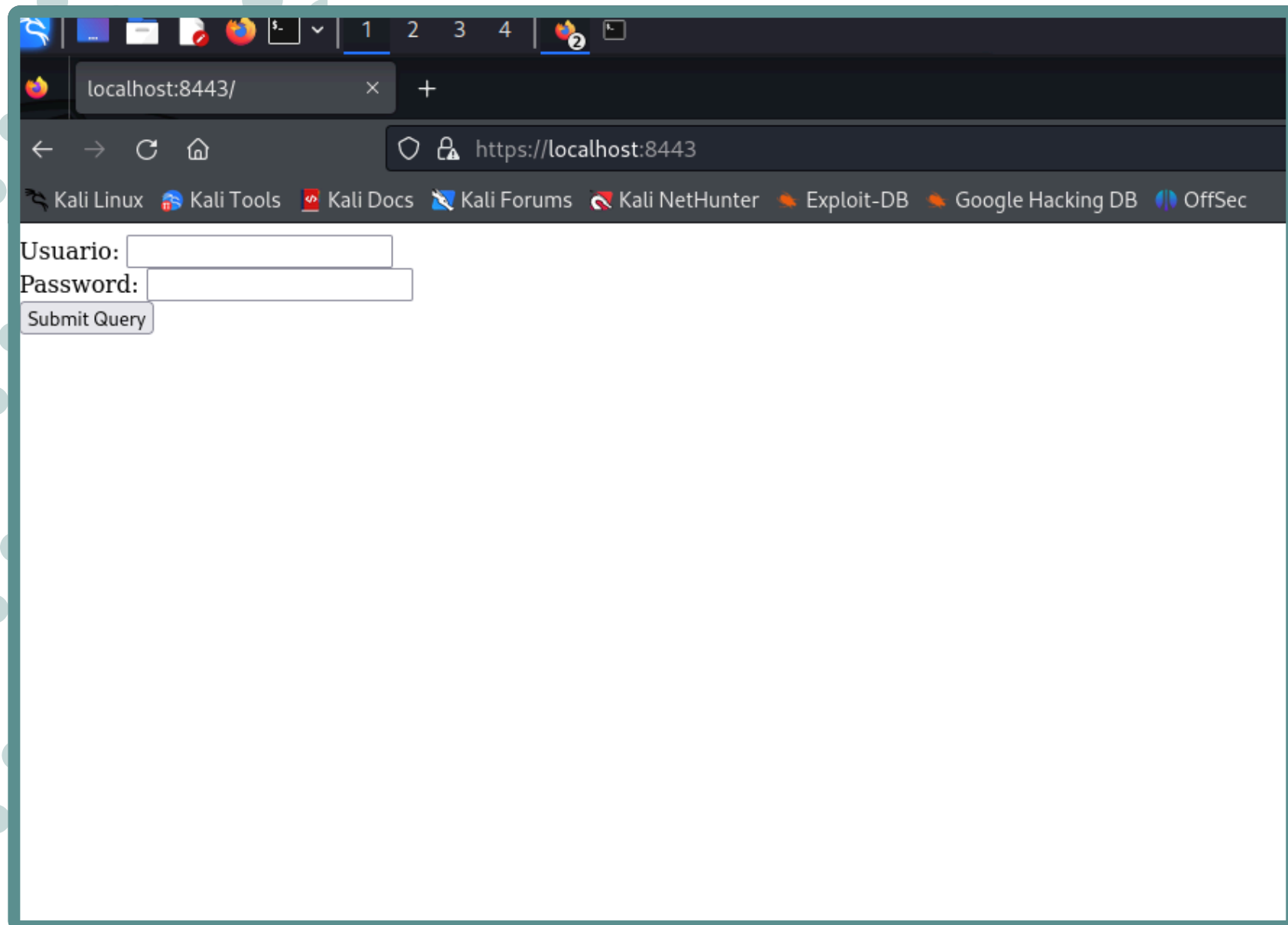
The screenshot shows a terminal window with the nano text editor open, editing the file `certs/nginx.conf`. The configuration is for an nginx server listening on port 443 with SSL. The server configuration block includes the `listen` directive, `ssl_certificate` and `ssl_certificate_key` paths, and a `location /` block pointing to `/usr/share/nginx/html`. The terminal window has a dark theme and a 'KALI' watermark. The top bar shows the user is `kali@kali` in the directory `~/lab3_seguridad`. The bottom status bar displays various keyboard shortcuts for nano.

```
GNU nano 8.1 certs/nginx.conf *
server {
    listen 443 ssl;

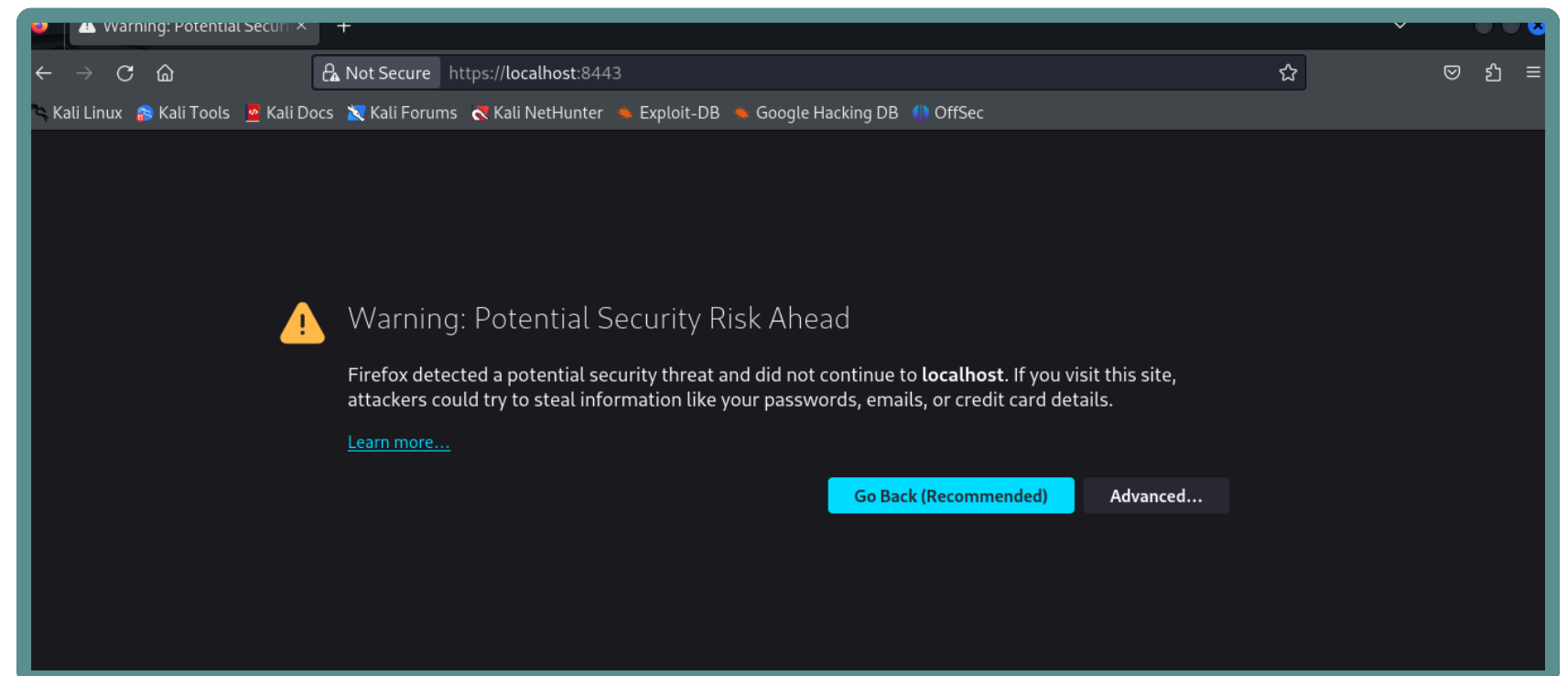
    ssl_certificate /etc/nginx/certs/server.crt;
    ssl_certificate_key /etc/nginx/certs/server.key;

    location / {
        root /usr/share/nginx/html;
        index index.html;
    }
}
```

VALIDACIÓN HTTPS

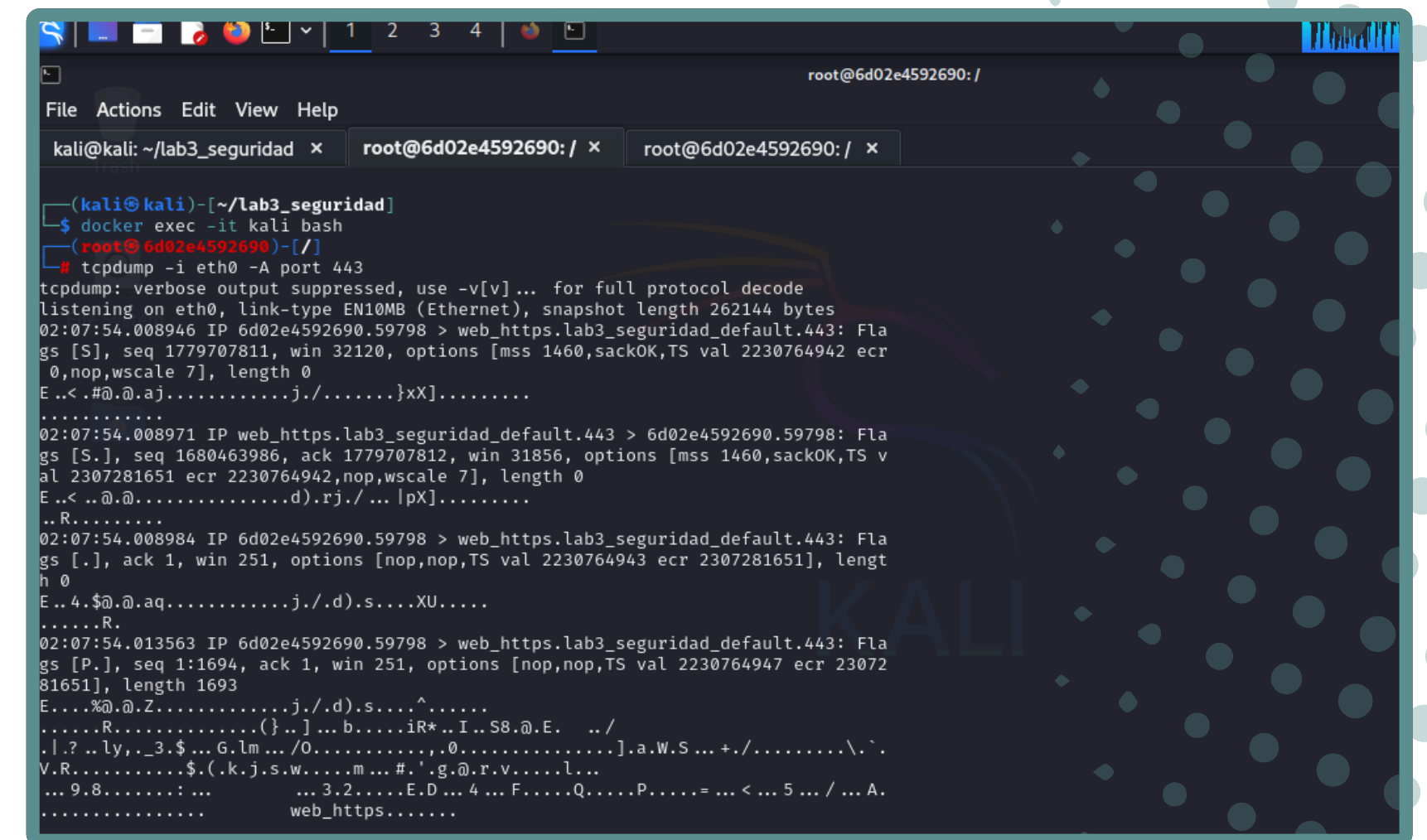


► Se accedió a **https://localhost:8443** desde el navegador para verificar el funcionamiento del canal seguro.



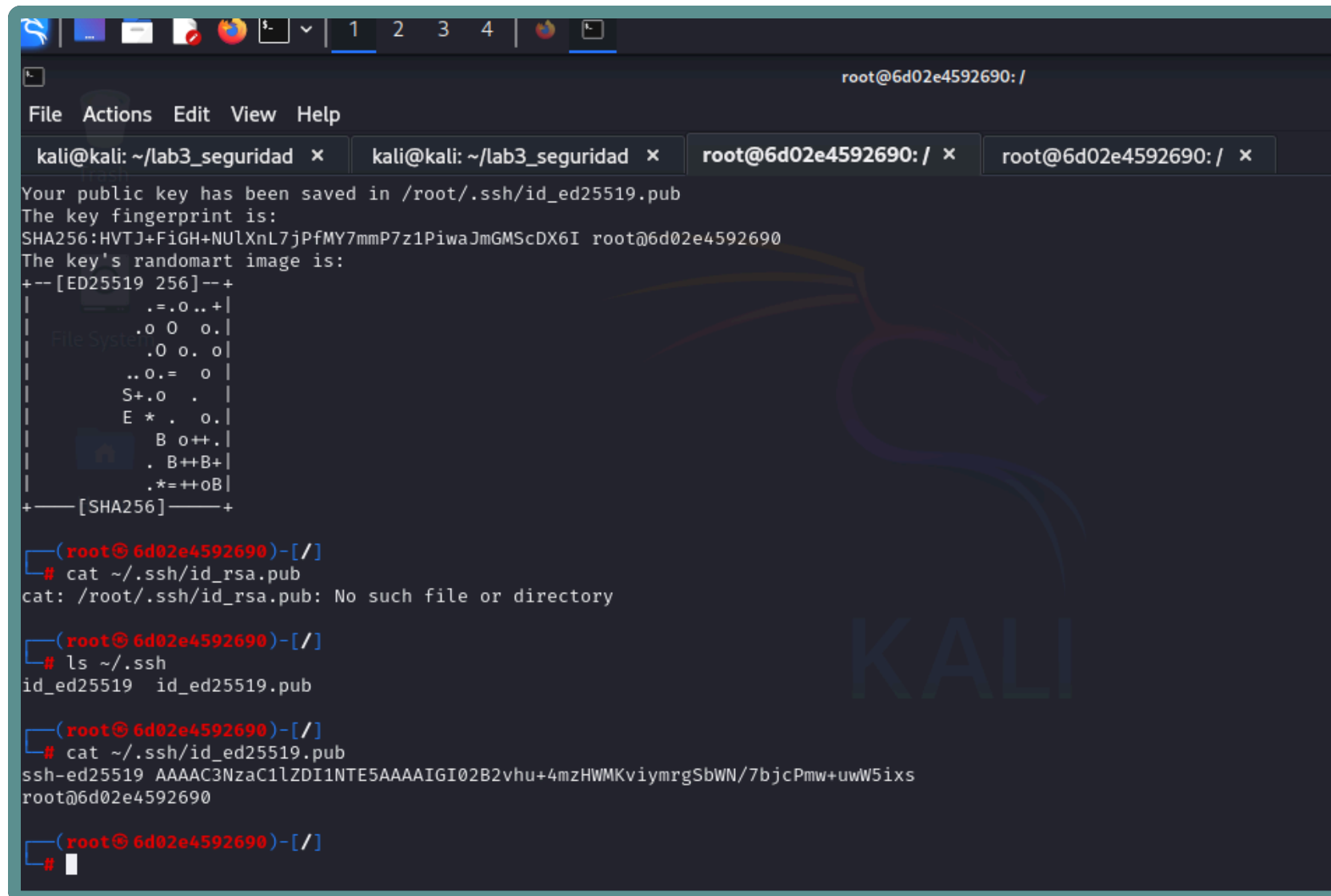
CAPTURA TRÁFICO HTTPS

- **Comando: `tcpdump -i eth0 -A port 443`**
La captura muestra datos completamente cifrados e ilegibles, evidenciando que el protocolo TLS protege efectivamente la información transmitida.



```
root@6d02e4592690: /  
File Actions Edit View Help  
kali@kali: ~/lab3_seguridad x root@6d02e4592690: / x root@6d02e4592690: / x  
root@kali:~/lab3_seguridad  
$ docker exec -it kali bash  
(root@6d02e4592690)-[/]  
# tcpdump -i eth0 -A port 443  
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode  
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes  
02:07:54.008946 IP 6d02e4592690.59798 > web_https.lab3_seguridad_default.443: Fla  
gs [S], seq 1779707811, win 32120, options [mss 1460,sackOK,TS val 2230764942 ecr  
0,nop,wscale 7], length 0  
E..<..#@.aj.....j./.....}xX].....  
.....  
02:07:54.008971 IP web_https.lab3_seguridad_default.443 > 6d02e4592690.59798: Fla  
gs [S.], seq 1680463986, ack 1779707812, win 31856, options [mss 1460,sackOK,TS v  
al 2307281651 ecr 2230764942,nop,wscale 7], length 0  
E..<..@.d.....d).rj./...lpX].....  
..R.....  
02:07:54.008984 IP 6d02e4592690.59798 > web_https.lab3_seguridad_default.443: Fla  
gs [.], ack 1, win 251, options [nop,nop,TS val 2230764943 ecr 2307281651], lengt  
h 0  
E..4.$@.aq.....j./d).s....XU....  
.....R.....  
02:07:54.013563 IP 6d02e4592690.59798 > web_https.lab3_seguridad_default.443: Fla  
gs [P.], seq 1:1694, ack 1, win 251, options [nop,nop,TS val 2230764947 ecr 23072  
81651], length 1693  
E...%@.Z.....j./d).s....^.....  
.....R.....({..]...b.....iR*..I..S8.@.E.  ../  
..l.?..ly,._3.$...G.lm.../O.....,0.....]a.W.S...+./.....\.'.V.R.....$.  
(.k.j.s.w....m...#.'g.@.r.v....l...  
...9.8.....: ... 3.2.....E.D...4...F....Q.....P.....=>...<...5.../...A.  
..... web_https.....
```

CONFIGURACIÓN SSH

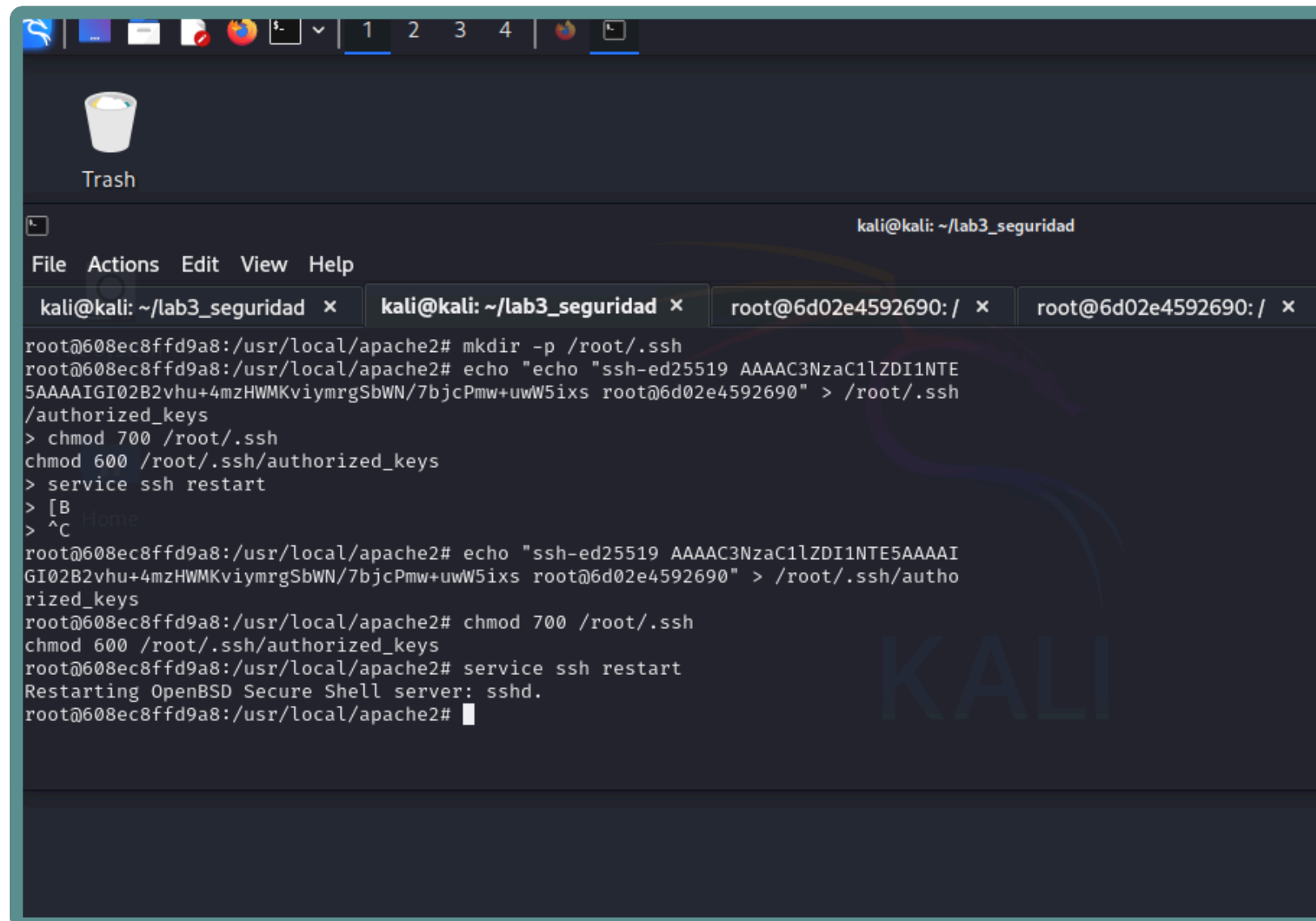


```
root@6d02e4592690: /  
File Actions Edit View Help  
kali@kali: ~/lab3_seguridad x kali@kali: ~/lab3_seguridad x root@6d02e4592690: / x root@6d02e4592690: / x  
Your public key has been saved in /root/.ssh/id_ed25519.pub  
The key fingerprint is:  
SHA256:HVTJ+FiGH+NULXnL7jPfMY7mmP7z1PiwaJmGMScDX6I root@6d02e4592690  
The key's randomart image is:  
+--[ED25519 256]--+  
|      .=.o..+|  
|     .o 0 o.|  
|    .o o. o|  
|   ..o.= o |  
|  S+.o . |  
| E * . o.|  
|  B o++.|  
| . B++B+|  
| .*=++oB|  
+---[SHA256]-----+  
  
(root@6d02e4592690)-[/]  
# cat ~/.ssh/id_rsa.pub  
cat: /root/.ssh/id_rsa.pub: No such file or directory  
  
(root@6d02e4592690)-[/]  
# ls ~/.ssh  
id_ed25519 id_ed25519.pub  
  
(root@6d02e4592690)-[/]  
# cat ~/.ssh/id_ed25519.pub  
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIGI02B2vhu+4mzHWMKviymrgSbWN/7bjcPmw+uwW5ixs  
root@6d02e4592690  
  
(root@6d02e4592690)-[/]  
#
```

► Se configura acceso seguro mediante claves SSH ed25519, eliminando la necesidad de contraseñas.

- Comando: `ssh-keygen -t ed25519`

CONFIGURACIÓN SSH



The screenshot shows a Kali Linux terminal window with a dark theme. The window title is "kali@kali: ~/lab3_seguridad". The terminal displays the following commands and output:

```
root@608ec8ffd9a8:/usr/local/apache2# mkdir -p /root/.ssh
root@608ec8ffd9a8:/usr/local/apache2# echo "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIGI02B2vhu+4mzHWMKviymrgSbWN/7bjcPmw+uwW5ixs root@6d02e4592690" > /root/.ssh/authorized_keys
> chmod 700 /root/.ssh
> chmod 600 /root/.ssh/authorized_keys
> service ssh restart
> [B
> ^C
root@608ec8ffd9a8:/usr/local/apache2# echo "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIGI02B2vhu+4mzHWMKviymrgSbWN/7bjcPmw+uwW5ixs root@6d02e4592690" > /root/.ssh/authorized_keys
root@608ec8ffd9a8:/usr/local/apache2# chmod 700 /root/.ssh
root@608ec8ffd9a8:/usr/local/apache2# chmod 600 /root/.ssh/authorized_keys
root@608ec8ffd9a8:/usr/local/apache2# service ssh restart
Restarting OpenBSD Secure Shell server: sshd.
root@608ec8ffd9a8:/usr/local/apache2#
```



Desde Apache

- Uso de openssh-server
 - Claves añadidas a `authorized_keys`
- "Configuración de acceso seguro mediante claves"**

EVIDENCIA: ACCESO SSH

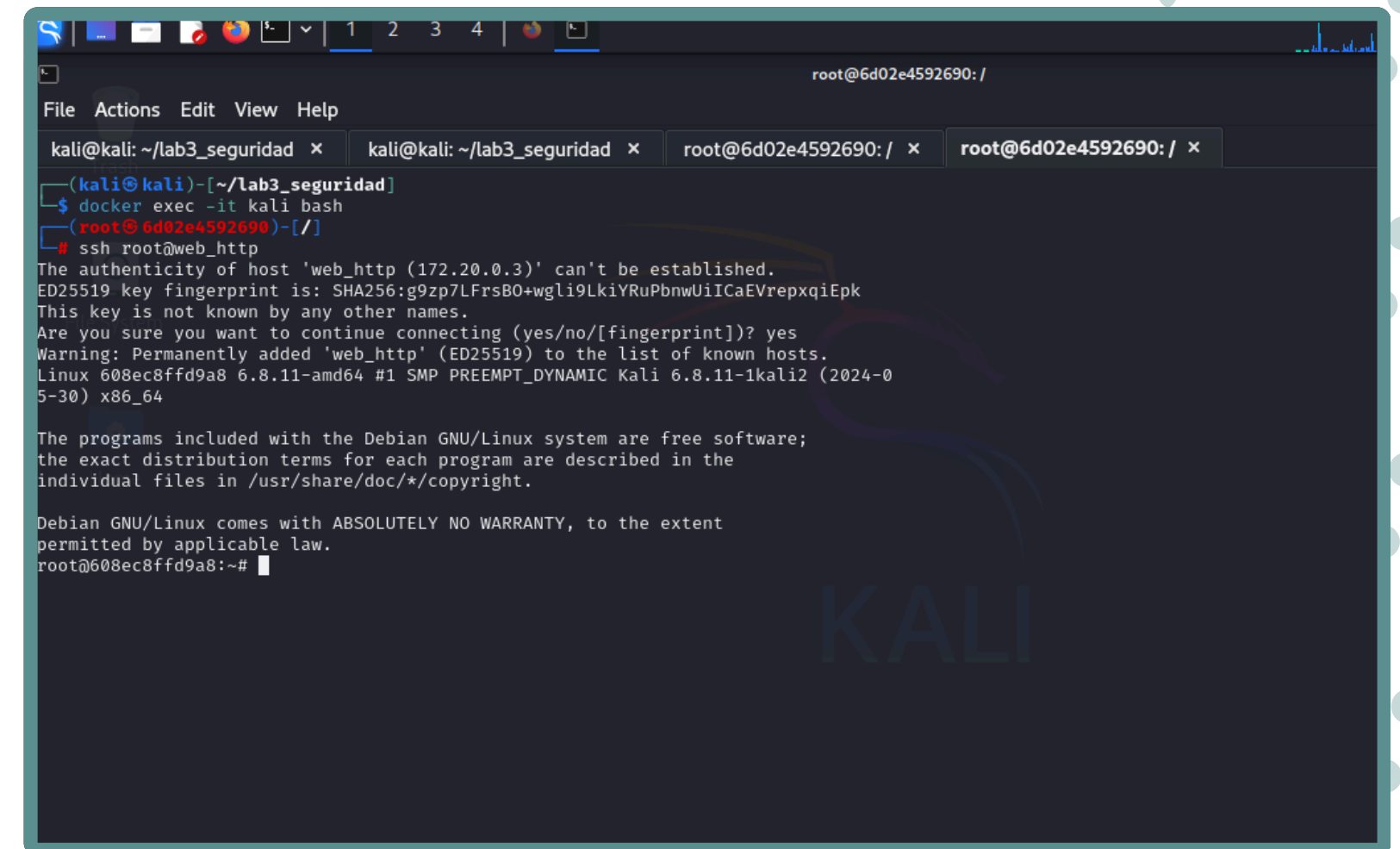
► Sesión SSH iniciada con autenticación por clave:

```
$ ssh root@web_http
```

```
root@container:~#
```

Autenticación exitosa sin contraseña mediante clave ed25519.

"Se implementó acceso seguro eliminando el uso de contraseñas"



```
root@6d02e4592690: /  
File Actions Edit View Help  
kali@kali: ~/lab3_seguridad x kali@kali: ~/lab3_seguridad x root@6d02e4592690: / x root@6d02e4592690: / x  
(kali@kali)~[~/lab3_seguridad]  
$ docker exec -it kali bash  
(root@6d02e4592690)~[/  
# ssh root@web_http  
The authenticity of host 'web_http (172.20.0.3)' can't be established.  
ED25519 key fingerprint is: SHA256:g9zp7LFrsB0+wgli9LkiYRuPbnwUiICaEVrepqiEpk  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added 'web_http' (ED25519) to the list of known hosts.  
Linux 608ec8ffd9a8 6.8.11-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.8.11-1kali2 (2024-05-30) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
root@608ec8ffd9a8:~#
```